

GPG (GNU Privacy Guard): Gestione e Uso delle Chiavi Asimmetriche

NECKER

18 Novembre 2025

Indice

1	GPG: Fondamenti e Web of Trust	2
1.1	PKI vs. GPG	2
1.2	Concetto di Fiducia (<i>Trust</i>) in PGP/GPG	2
1.3	Validità della Chiave (<i>Key Validity</i>)	2
1.4	Crittografia Simmetrica con GPG (Senza Chiavi Asimmetriche)	3
2	Generazione e Gestione delle Chiavi Asimmetriche	4
2.1	Generazione delle Chiavi Asimmetriche	4
2.2	Elenco e Ispezione delle Chiavi	4
3	Crittografia e Firma dei Dati	5
3.1	Crittografia Asimmetrica (Riservatezza)	5
3.2	Firma dei Dati (Autenticazione e Integrità)	6
4	Firma delle Chiavi (Web of Trust)	6
5	Interazione con i Keyserver e Altri Utenti	7
5.1	Importazione ed Esportazione delle Chiavi	7
5.2	Interazione con un Key Server	7

1 GPG: Fondamenti e Web of Trust

Questa sezione introduce GPG (GNU Privacy Guard), il suo contesto e i concetti di fiducia (Trust) e validità (Validity) che lo distinguono dall'infrastruttura a chiave pubblica (PKI) tradizionale.

1.1 PKI vs. GPG

GPG (GNU (GNU's Not Unix: quindi progetto libero open-source) Privacy Guard) è la suite software che sostituisce il protocollo (PGP Pretty Good Privacy, software proprietario ma stesso funzionamento del suo successore **GPG**) ed è pienamente conforme allo standard **OpenPGP**. Sebbene entrambi utilizzino la crittografia asimmetrica, differiscono drasticamente nel modello di gestione della fiducia.

Tabella 1: Confronto Modelli di Fiducia: PKI vs. PGP/GPG

Caratteristica	PKI (Esempio: HTTPS)	PGP/GPG (Web of Trust)
Fonte di Fiducia	Gerarchica/Centralizzata (Autorità di Certificazione - CA).	Decentralizzata (Utenti individuali).
Base della Fiducia	La fiducia nella chiave di X è garantita dalla firma di una CA accreditata e pre-approvata.	La fiducia nella chiave di X deriva dalle firme di altri utenti che si fidano di X.
Verifica Identità	Doveri della CA (verifica l'identità del proprietario del certificato).	Doveri dell'utente (ogni utente verifica l'identità e firma le chiavi di cui si fida).

1.2 Concetto di Fiducia (*Trust*) in PGP/GPG

In GPG, la **fiducia** (*Trust*) riflette quanto un utente si fida di un altro utente nell'accuratezza e nell'affidabilità della **verifica delle identità di terze parti** e della firma delle loro chiavi.

- **Fiducia del Proprietario (Owner Trust):** Lista per ogni chiave con tutti i soggetti a cui assegno un grado di fiducia nel verificarla (valore deve essere **impostato manualmente dall'utente**) per ogni chiave presente nel proprio portachiavi (*keyring*).
- **Scopo:** Determinare chi è autorizzato a firmare chiavi nel proprio *keyring* per convalidarle.
- **Livelli di Fiducia:** La fiducia può essere impostata a diversi livelli:
 - **Completa (*Full Trust*):** L'utente si fida pienamente che questa persona verifichi correttamente e firmi le chiavi di altri.
 - **Marginale (*Marginal Trust*):** L'utente si fida parzialmente o con riserva di questa persona nella verifica delle chiavi altrui.
 - **Nessuna (*Untrusted*):** L'utente non si fida affatto.

1.3 Validità della Chiave (*Key Validity*)

La **validità della chiave** è la certezza che la chiave pubblica in questione appartenga effettivamente all'entità con cui si desidera comunicare. È un valore calcolato automaticamente da GPG basato su due fattori:

$$\text{Validità} = f(\text{Fiducia del Proprietario}, \text{Numero di Firme sulla Chiave})$$

La validità determina se è sicuro crittografare i dati per quella chiave.

- **Validità e Firme:** Affinché una chiave venga considerata ”**valida**” da GPG nel proprio sistema, sono necessari:
 - **Una sola firma** di una chiave che l’utente ha contrassegnato con **Fiducia Completa** (*Full Trust*),
 - **Oppure** almeno **tre firme** di chiavi che l’utente ha contrassegnato con **Fiducia Marginale** (*Marginal Trust*).
- **Flusso:** L’utente imposta il *Trust* → PGP/GPG calcola la *Validità* basandosi su quel Trust e sul numero di firme.

1.4 Crittografia Simmetrica con GPG (Senza Chiavi Asimmetriche)

Oltre all’uso asimmetrico, GPG può essere utilizzato per la sola crittografia simmetrica, basata su una passphrase (chiave simmetrica da usare per cifrare).

Per cifrare un file basterà aprire un terminale e digitare:

Tabella 2: Crittografia Simmetrica GPG

Comando	Descrizione
<code>gpg --symmetric <input></code>	Cifra il file specificato utilizzando un algoritmo simmetrico (es. AES) protetto da una passphrase . La chiave pubblica non è necessaria.
<code>[--cipher-algo <algo>]</code>	Specifica l’algoritmo simmetrico da utilizzare (es. AES256).
<code>[--output <name>]</code>	Specifica il nome del file cifrato di output.
<code>[--armor]</code>	Utilizza il formato ASCII Armored (.asc, assicura la non corruzione dei dati durante il trasporto).
<code>gpg -d <data></code>	Decifra i dati crittografati simmetricamente. Richiede la corretta passphrase .

```
gpg [--output <nome\_file\_cifrato>] --symmetric [--cipher-algo <algoritmo>] [--armor] <file\_di\_input>
```

Esempio:

```
gpg --output documento.txt.gpg --symmetric documento.txt
```

```
gpg [--output <nome\_file\_decifrato>] -d <file\_cifrato>
```

Esempio:

```
gpg --output documento\_originale.txt -d documento.txt.gpg
```

2 Generazione e Gestione delle Chiavi Asimmetriche

I comandi `gpg` per la generazione e la gestione delle chiavi sono fondamentali per iniziare a utilizzare la crittografia asimmetrica.

2.1 Generazione delle Chiavi Asimmetriche

La generazione della chiave GPG crea una coppia di chiavi: una **chiave pubblica** (da distribuire) e una **chiave segreta/privata** (da mantenere al sicuro).

Tabella 3: Comandi per la Generazione delle Chiavi GPG

Comando	Modalità	Descrizione
<code>gpg --generate-key</code> <code>gpg --gen-key</code>	Veloce	Generazione rapida. Richiede solo nome, email e passphrase. Le opzioni predefinite (algoritmo, lunghezza, scadenza) vengono utilizzate automaticamente.
<code>gpg --full-generate-key</code> <code>gpg --full-gen-key</code>	Completa	Generazione completa. Permette di specificare dettagliatamente l'algoritmo (es. RSA, ECC), la lunghezza della chiave (es. 2048, 4096 bit) e la data di scadenza.

2.2 Elenco e Ispezione delle Chiavi

Per visualizzare e gestire le chiavi presenti nel proprio **keyring** (portachiavi).

Tabella 4: Comandi per l'Elenco e l'Ispezione delle Chiavi

Comando	Descrizione
<code>gpg --list-keys</code> <code>gpg -k</code>	Elenca tutte le chiavi pubbliche presenti nel keyring dell'utente. Vengono mostrati Key ID e Fingerprint (la chiave pubblica hashata).
<code>gpg --list-secret-keys</code>	Elenca tutte le chiavi segrete (private) presenti nel keyring dell'utente. Queste chiavi sono necessarie per decifrare e firmare.
<code>gpg --edit-key <key></code>	Apri l'interfaccia di modifica interattiva per la chiave specificata (tramite UID, Key ID o Fingerprint). Mostra informazioni aggiuntive come il livello di trust (fiducia) e permette operazioni avanzate come: • Aggiungere nuove UID (User IDs). • Aggiungere subkeys (sotto-chiavi). • Impostare il livello di fiducia (trust). • Firmare altre chiavi.

3 Crittografia e Firma dei Dati

Questi sono i comandi principali per applicare le funzioni di base della crittografia asimmetrica: riservatezza e autenticazione.

3.1 Crittografia Asimmetrica (Riservatezza)

Per crittografare i dati, è necessaria la **chiave pubblica** del destinatario. Solo il destinatario può decifrare con la sua **chiave privata**.

Tabella 5: Crittografia e Decifratura dei Dati

Sintassi e Opzioni	Funzione
<code>gpg --encrypt <data></code> <code>gpg -e <data></code>	Crittografa i dati specificati (di solito un file).
<code>-r <recipient></code>	Specifica l'identificatore del destinatario. La sua chiave pubblica sarà utilizzata per la crittografia. Se omissa, GPG chiederà i destinatari.
<code>[--output <name>]</code>	Specifica il nome del file cifrato di output (default: aggiunge <code>.gpg</code> o <code>.asc</code>).
<code>[--armor]</code>	Output in formato ASCII Armored (<code>.asc</code>).
<code>gpg -d <data></code>	Decifra i dati specificati. Richiede la chiave segreta del destinatario nel keyring locale e la passphrase .
<code>[--local-user <UID>]</code>	Specifica quale chiave segreta utilizzare per la decifratura, utile se l'utente possiede più chiavi.

```
gpg -e -r <Destinatario> [--armor] <file_di_input>
```

Esempio:

```
gpg --encrypt --recipient alice --armor rapporto.pdf
```

```
gpg [--output <nome_file_decifrato>] -d <file_cifrato>
```

Esempio:

```
gpg --output documento_originale.txt -d documento.txt.gpg
```

3.2 Firma dei Dati (Autenticazione e Integrità)

La firma utilizza la **chiave segreta** del mittente per autenticare l'origine e garantire che i dati non siano stati manomessi.

Tabella 6: Comandi per la Firma dei Dati

Comando e Opzioni	Descrizione
<code>gpg --sign <data></code>	Crea un file cifrato e firmato (firmacifrato). La firma è inclusa nel file di output.
<code>gpg --clearsign <data></code>	Crea un output leggibile (non cifrato, la firma è nel corpo del testo). Non avviene compressione , rendendo il risultato leggibile direttamente. (senza firma, deve essere aggiunta separatamente)
<code>gpg --detach-sign <data></code>	Crea la firma in un file separato (di solito <code>.sig</code> o <code>.asc</code>). Il file dati originale rimane inalterato. Utile per file di grandi dimensioni.
<code>[-u <UID/Fingerprint>]</code>	Specifica quale chiave segreta (<code>--local-user</code> nella forma lunga) utilizzare per la firma.
<code>[--armor]</code>	Output della firma in formato ASCII Armored.
<code>gpg --verify <signature></code>	Verifica una firma (separata o inclusa) rispetto al file di dati. Richiede la chiave pubblica del mittente nel keyring locale.

4 Firma delle Chiavi (Web of Trust)

Il concetto di **Web of Trust** (Rete di Fiducia) in PGP/GPG si basa sulla firma reciproca delle chiavi per stabilire la validità.

Tabella 7: Firma e Verifica delle Chiavi

Comando	Descrizione
<code>gpg --sign-key <KeyId></code>	Firma la chiave pubblica specificata (di un altro utente) utilizzando la propria chiave segreta. Con questo atto, si attesta che l'identità associata alla chiave è stata verificata.
<code>[-u <UID/Fingerprint>]</code>	Specifica quale delle proprie chiavi segrete utilizzare per firmare la chiave di destinazione.
<code>gpg --list-signs <key></code>	Mostra l'elenco di tutte le chiavi presenti nel keyring che hanno firmato la specifica chiave di destinazione. Questo aiuta a valutare il livello di fiducia e la diffusione della chiave.

5 Interazione con i Keyserver e Altri Utenti

Questi comandi consentono lo scambio di chiavi tra utenti e l'interazione con i **keyserver** pubblici.

5.1 Importazione ed Esportazione delle Chiavi

Tabella 8: Comandi per Importazione ed Esportazione delle Chiavi

Sintassi e Opzioni	Funzione
<code>gpg --export <UID/Fingerprint></code>	Esporta la chiave pubblica specificata. Di default, l'output è in formato binario e viene scritto sullo standard output.
<code>[--output <keyname>]</code>	Specifica un file di destinazione per la chiave esportata.
<code>[--armor]</code>	Utilizza il formato ASCII (<code>.asc</code>) anziché binario. Questo formato leggibile e facile da copiare/incollare è chiamato ASCII Armored .
<code>gpg --import <filename></code>	Importa la chiave pubblica contenuta nel file specificato nel keyring dell'utente.

5.2 Interazione con un Key Server

I **Keyserver** (Server delle Chiavi) agiscono come registri pubblici e decentralizzati del Web of Trust. È cruciale comprendere che devono contenere solo informazioni pubbliche e autenticate, mai dati riservati.

- **Cosa Inserire (Dati Pubblici):**

Il Keyserver è destinato a ricevere dati che contribuiscono alla **validazione** e alla **reperibilità** della chiave.

1. **La Tua Chiave Pubblica:**

- È il dato essenziale che permette agli altri di cifrare i messaggi per te.
- Include la tua User ID (UID) e la **firma di auto-certificazione** generata con la tua chiave privata, che ne attesta l'autenticità iniziale.

2. **Le Firme che Hai Apposto (Atti di Fiducia):**

- Dopo aver verificato l'identità di un'altra persona (es. Mario), le **firme sulla sua chiave generate dalla tua chiave privata** vengono caricate.
- Questo notifica al mondo che tu (l'identità dietro la tua chiave) ti fidi dell'identità di Mario, contribuendo al calcolo della validità della sua chiave per chi si fida di te.

- **Verifica Veridicità della Chiave:**

Per verificare se una chiave in un **keyserver**, guardo nel mio **keyring** (lista di gente di cui mi fido), se qualcuno l'ha firmata.

Comandi per interagire con il keyserver:

Tabella 9: Interazione con Key Server

Comando	Descrizione
<code>gpg --keyserver <url> --search-keys <UID/KeyId></code>	Cerca sul keyserver specificato la chiave corrispondente all'identificatore fornito (UID, Key ID o Fingerprint).
<code>gpg --keyserver <url> --send-keys <KeyId></code>	Invia la propria chiave pubblica (identificata dal Key ID) al keyserver specificato, rendendola disponibile ad altri utenti.
<code>gpg --keyserver <url> --recv-keys <KeyId></code>	Cerca la chiave specificata sul keyserver e la importa nel keyring locale dell'utente.